המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 21/08/2025 שעת הבחינה: 15:00
שנה"ל: תשפ"ה סמסטר: ב' מועד: ב'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 15:20, 15:50. לזכאי תוספת זמן גם בשעה 16:20

נא **לא לשאול** את השאלות הבאות בעזרת פתקים, כי לא יינתן עליהם מענה:
- יש טעות בבחינה/בשאלה/בסעיף...
- יש יותר מתשובה אחת נכונה או אף אחת מהתשובות לא נכונה.
- לא למדנו על...
- מה התרגום של [משהו] בעברית/באנגלית...
- מה המשמעות של ראשי התיבות...
- כל שאלה שעיקרה לגרום לגילוי התשובה

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)

- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, סעיף א הוא התשובה הנכונה

<u>שאלה מספר 1:</u>

בהקשר של חתימה דיגיטלית לפי textbook RSA (כלומר ללא hash), אם ידוע שה private key הוא:

n = 33

d = 7

ונתונה החתימה הדיגיטלית σ כאשר σ=30. מהי ההודעה המקורית שחתמו עליה?

א. 6

ב. 5

ג. 7

ד. 4

<u>שאלה מספר 2:</u>

כאשר לקוח בודק את שרשרת התעודות (Chain of trust) ב-TLS, מה הוא בודק?

א. חתימות דיגיטליות תקינות על התעודות עד ל Root CA שהוא סומך עליו

ב. מפתח סימטרי תואם

ג. התאמה בין המפתח הציבורי למפתח הפרטי של הלקוח

ד. זמן פקיעה זהה של כל התעודות בשרשרת

<u>שאלה מספר 3:</u>

למה גורם דגל הHttpOnly בעוגיות?

א. מונע גישה באמצעות JavaScript לעוגיה

ב. מונע שליחה של העוגיה ל-DOM

ג. מאפשר שמירת מפתחות הצפנה בצד הלקוח

ד. מונע שליחה של העוגיה ב-HTTPS

<u>שאלה מספר 4:</u>

נתון הפסאדו-קוד הבא:

```
def receive_secure_message(ciphertext, k1, k2):
    decrypted = decrypt(ciphertext, k1)

    (message, tag) = separate_to_message_and_tag(decrypted)

    if mac(message, k2) != tag:
        raise Exception("Authentication failed!")

    return message
```

איזו מהשיטות הבאות היא השיטה שהשתמשו בה?

א. MAC-then-Encrypt

ב. Encrypt-then-MAC

ג. Encrypt-and-MAC

ד. Salt-and-Pepper

<u>שאלה מספר 5:</u>

כיצד מבוצעת אימות עסקה ברשת ביטקוין?

א. על ידי הכורים המאמתים את העסקה ומוסיפים אותה לבלוק הבא

ב. על ידי הרשויות הממשלתיות בלבד

ג. על ידי המשתמש ששולח את העסקה

ד. על ידי שרת מרכזי של ביטקוין

<u>שאלה מספר 6:</u>

נתון דף אינטרנט שמוצג בגלישה לURL הבא:

http://foo.com/?name=VALUE

הדף מציג את הערך של הפרמטר name ישירות בתוך תגית HTML כך:

** Welcome, VALUE **

ללא כל סינון או קידוד של התוכן שמגיע מה-URL.

בנוסף, בדף יש טופס עם Anti-CSRF Token שמוצג בטופס כך:

```
<form method="POST" action="/update_password">
<input type="hidden" name="csrf_token" value="random_token_value">
<input type="password" name="new_password">
<input type="submit" value="Submit">
</form>
```

כאשר במקום random_token_value יופיע token אקראי שהשרת בחר.

איזו מהטענות הבאות <u>אינה</u> נכונה?

א. ה-CSRF Token לא יכול להיגנב כי הוא ב-POST בלבד ולא ב-URL

ב. הדף פגיע ל-Reflected XSS מכיוון שהפרמטר name מוצג ללא סינון

ג. תוקף יכול להזריק קוד JavaScript ב-name ולגנוב את ה-csrf_token מהטופס

ד. גניבת ה-csrf_token מאפשרת לתוקף לבצע בקשות POST עם טוקן תקין שהשרת יקבל כתקין

<u>שאלה מספר 7:</u>

אתר מסחר אלקטרוני גדול מגלה שהמפתח הפרטי של תעודת ה-SSL/TLS שלו נגנב. הוא פונה ל CA שהנפיק לו את התעודה, וה CA מבטל את התעודה באופן מיידי. למרות זאת, חוקרי אבטחה מדווחים כי דפדפנים של משתמשים רבים עדיין מקבלים את התעודה הגנובה כתקפה במשך שעות לאחר הביטול הרשמי, ומאפשרים לתוקפים להפעיל אתרי פישינג.

מבין האפשרויות הבאות, מהי סיבה אפשרית לפער הזמנים בין הביטול הרשמי לחוסר האפקטיביות שלו בפועל אצל משתמשי קצה?

א. כאשר דפדפנים נתקלים בבעיית תקשורת רגעית או עיכוב בקבלת תשובה משרתי הביטול המוסמכים מטעם ה-CA, הם בוחרים להתייחס לתעודה כתקפה כדי לא לפגוע בחוויית המשתמש (מדיניות Fail-Soft)

ב. שרתי אתר המסחר השתמשו ב-OCSP Stapling. התוקפים משתמשים במפתח הפרטי שגנבו כדי לחתום על אישור ה OCSP Stapling

ג. יומני ה Certificate Transparency טרם התעדכנו באופן גלובלי בסטטוס הביטול. דפדפנים מסוימים המסתמכים על יומנים אלה לקבלת מידע נוסף על תעודות, מפספסים את עובדת הביטול

ד. העדכון של כל שרתי השורש (Root Servers) בעולם לוקח מספר ימים

<u>שאלה מספר 8:</u>

נתון הפרוטוקול הבא להעברה של מפתח משותף K מאליס לבוב:

1. **אליס מגרילה באקראי מפתח ארוך K.**
2. **אליס מגרילה מחרוזת K_A חד פעמית אקראית באורך |K|.**
3. **אליס מחשבת את K_1 באופן הבא: $K_1 = K \text{ xor } K_A$, ואליס שולחת את K_1 לבוב.**
4. **בוב מגריל מחרוזת K_B חד פעמית אקראית באורך $|K_1|$.**
5. **בוב מחשב את K_2 באופן הבא: $K_2 = K_1 \text{ xor } K_B$, ושולח לאליס את K_2.**
6. **אליס מחשבת את K_3 באופן הבא: $K_3 = K_2 \text{ xor } K_A$, ואליס שולחת את K_3 לבוב.**
7. **בוב מחשב: $K_3 \text{ xor } K_B$, ומקבל את K.**

איזו מהטענות הבאות נכונה?

א. הפרוטוקול אינו מוגן כנגד אויב מאזין

ב. הפרוטוקול מוגן כנגד אויב מאזין אך אינו מוגן כנגד אויב MitM

ג. הפרוטוקול מוגן כנגד אויב מאזין וגם מוגן כנגד אויב MitM

ד. הפרוטוקול מוגן כנגד אויב MitM, בתנאי שהאויב לא יכול לעכב הודעות

<u>שאלה מספר 9:</u>

איזו מהטענות הבאות נכונה?

א. צופן בלוקים פחות מאובטח מצופן One time pad (בגלל תכונת ה perfect secrecy)

ב. ב PKI, שרת אינטרנט X שקיבל תעודה חתומה מ CA על ה public key של שרת האינטרנט, חייב ש ה CA שנתן לו (ל X) את התעודה יהיה ב root store של הלקוחות

ג. ב TLS, שרת אינטרנט חייב לייצר בעצמו תעודה עבור כל חיבור TLS

ד. הקמת חיבור TLS מחייבת שימוש בתעודה רק במקרה והחיבור מוקם בין שני שרתים

<u>שאלה מספר 10:</u>

איזה מהאלגוריתמים הבאים הוא אלגוריתם השייך לקריפטוגרפיה א-סימטרית?

א. RSA

ב. MAC

ג. HASH

ד. AES

--- סוף המבחן ---